

CanlıFal — Yetki ve Roller Dokümantasyonu

§85 — Spec Referansı: §6 Authorization, §85 Permission Document

Son güncelleme: 2026-08-27 | Envanter: 214 model, 776 handler

1. Rol Hiyerarşisi

Rol	Anahtar	Seviye	Açıklama
Süper Yönetici	yonetici	100	Tam yetki, finansal işlemlerden muaf personel
Admin	admin	100	Tam yetkili sistem yöneticisi
Finans	finans	60	Finansal işlemler ve raporlama
Moderatör	moderator	40	İçerik ve kullanıcı moderasyonu
Kullanıcı	user	0	Standart kullanıcı (varsayılan)

Oda İçi Roller (ChatUserRole)

Oda bazlı roller, global rollerden bağımsız olarak chatUserRole tablosunda tutulur.

Rol	Seviye	Açıklama
superadmin	5	Oda süper yöneticisi
founder	4	Oda kurucusu
sop	3	Süper operatör
op	2	Operatör
voice	1	Ses yetkisi
none	0	Yetki yok

Global admin bypass: user.role değeri admin, moderator veya site_manager ise oda içinde otomatik olarak superadmin yetkisine sahiptir.

2. Yetki Kataloğu (19 Permission)

Yetkiler 4 gruba ayrılmıştır:

2.1 Finans (finance)

Yetki Anahtarı	Açıklama
finance.balance.adjust	Bakiye düzenleme
finance.withdrawal.view	Para çekme taleplerini görme
finance.withdrawal.approve	Para çekme onaylama
finance.payment.manage	Ödeme taleplerini yönetme
finance.ledger.view	Finansal defteri görme
finance.report.view	Finansal raporları görme

2.2 İçerik (content)

Yetki Anahtarı	Açıklama
content.gift.manage	Hediyeleri yönetme
content.teller.manage	Falcıları yönetme
content.announcement.manage	Duyuruları yönetme
content.media.upload	Medya yükleme

2.3 Moderasyon (moderation)

Yetki Anahtarı	Açıklama
moderation.user.ban	Kullanıcı yasaklama
moderation.user.mute	Kullanıcı susturma
moderation.room.manage	Odaları yönetme
moderation.report.handle	Şikayetleri işleme

2.4 Sistem (system)

Yetki Anahtarı	Açıklama
system.feature.toggle	Özellik bayraklarını değiştirme
system.config.manage	Uzak yapılandırma yönetimi
system.audit.view	Denetim kaydını görme
system.role.manage	Rol ve yetki yönetimi
system.admin.full	Tam yönetici erişimi

3. Rol → Yetki Matrisi

Yetki	admin	yonetici	finans	moderator	user
fin- ance.balance .adjust	✓	✓	✓	✗	✗
fin- ance.withdra wal.view	✓	✓	✓	✗	✗
fin- ance.withdra wal.approve	✓	✓	✓	✗	✗
fin- ance.paymen t.manage	✓	✓	✓	✗	✗
fin- ance.ledger.v iew	✓	✓	✓	✗	✗
fin- ance.report.v iew	✓	✓	✓	✗	✗
con- tent.gift.man age	✓	✓	✗	✗	✗
con- tent.teller.ma nage	✓	✓	✗	✗	✗
con- tent.announc ement.mana ge	✓	✓	✗	✓	✗
con- tent.media.u pload	✓	✓	✗	✗	✗
modera- tion.user.ban	✓	✓	✗	✓	✗
modera- tion.user.mut e	✓	✓	✗	✓	✗

Yetki	admin	yonetici	finans	moderator	user
moderation.room.manage	✓	✓	✗	✓	✗
moderation.report.handle	✓	✓	✗	✓	✗
system.feature.toggle	✓	✓	✗	✗	✗
system.config.manage	✓	✓	✗	✗	✗
system.audit.view	✓	✓	✓	✗	✗
system.role.manage	✓	✓	✗	✗	✗
system.admin.full	✓	✓	✗	✗	✗

4. Auth Mekanizması

4.1 Dual Authentication

Tüm korumalı uç noktalar iki yol ile doğrulanır:

1. **Mobile JWT** — `Authorization: Bearer <access_token>` (7 gün geçerli, refresh 30 gün)
2. **Web NextAuth Session** — `next-auth` session cookie

`authenticateRequest(req)` → mobile JWT önce, ardından web session fallback.

4.2 Guard Helper'ları

Helper	Kaynak	Davranış
<code>resolveUser(req)</code>	<code>lib/rbac.ts</code>	Dual auth → {id, role, email} veya null
<code>requireAuth(req)</code>	<code>lib/rbac.ts</code>	401 döner (unauthenticated)
<code>requireAdmin(req)</code>	<code>lib/rbac.ts</code>	401/403 (ADMIN_ROLES dışı)
<code>requireFullAdmin(req)</code>	<code>lib/rbac.ts</code>	401/403 (sadece admin/yonetici)
<code>requireRole(req, roles)</code>	<code>lib/rbac.ts</code>	401/403 (verilen rol listesi dışı)
<code>requireOwnerOrAdmin(req, ownerId)</code>	<code>lib/rbac.ts</code>	Kaynak sahibi veya admin
<code>isAdminRole(role)</code>	<code>lib/admin-utils.ts</code>	admin/yonetici/moderator/finans
<code>isFullAdmin(role)</code>	<code>lib/admin-utils.ts</code>	admin/yonetici
<code>hasPermission(role, perm)</code>	<code>lib/permissions.ts</code>	DB + legacy fallback

4.3 Yetki Kontrol Akışı

```

İstek → authenticateRequest (JWT) → fallback → getServerSession (web)
  → resolveUser → {id, role}
  → hasPermission(role, 'finance.withdrawal.approve')
    → DB'de rol var? → DB yetki listesi kontrol
    → DB'de yok? → SYSTEM_ROLES legacy matris kontrol
    → admin/yonetici? → DAİMA true

```

5. Oda İçi Yetki Kontrolleri

İşlem	Minimum Oda Rolü	Global Admin Bypass
Kullanıcı sessize alma (mute)	op (2)	✓
Kullanıcı kovma (kick)	op (2)	✓
Kullanıcı yasaklama (ban)	sop (3)	✓
Koltuk yönetimi	op (2)	✓
Oda sahipliğini devretme	founder (4) / owner	✓
Oda kapatma	owner	✓
Şifre değiştirme	owner	✓
Oda ayarlarını düzenleme	sop (3)	✓

6. Finansal İşlem Yetkileri

İşlem	Yetki	Ek Koşul
Bakiye düzenleme	finance.balance.adjust	Audit log yazılır
Para çekme onaylama	finance.withdrawal.approve	Audit log yazılır
Defter görüntüleme	finance.ledger.view	Salt okunur
Personel harcaması	isStaffSpender(role) → admin/yonetici	Finansal işlem yapılmaz

7. Admin API Uçları Yetki Gereksinimleri

API Endpoint	Gerekli Rol
admin/credits	ADMIN_ROLES
admin/withdrawals	ADMIN_ROLES
admin/feature-flags/*	isAdminRole
admin/remote-config/*	isAdminRole
admin/roles/*	isAdminRole
admin/risk-events	isAdminRole
admin/audit-logs	isAdminRole
admin/ledger	isAdminRole
admin/gifts/*	isAdminRole
admin/support	isAdminRole
admin/verification	isAdminRole
admin/effect-rules/*	isAdminRole
admin/chat-rooms	isAdminRole
admin/users/*	ADMIN_ROLES
admin/celebrities/*	isAdminRole
admin/trends/*	isAdminRole

8. Flutter Entegrasyonu

Token Yönetimi

- Access token: 7 gün (exp claim)
- Refresh token: 30 gün
- Token yenileme: POST /api/mobile/refresh-token

Yetki Bilgisi Edinme

- GET /api/v1/bootstrap → user.role alanı
- GET /api/effects/resolve → kullanıcı efektleri (rol/seviye bazlı)

Yetki Kontrol Kuralı

Flutter **asla** yerel yetki kararı almaz. Her işlem için backend'e istek gönderir; 403 yanıtı alırsa "Bu işlem için yetkiniz yok" mesajı gösterir.

9. Yetki Yönetim Paneli

URL: /admin/roles

- Tüm rolleri ve yetki matrisini görüntüler
- Rol oluşturma/düzenleme/silme (isSystem=false olanlar)
- Gruplu checkbox matrisi ile yetki atama
- Değişiklikler audit log'a yazılır (role_create , role_update , role_delete)